ITSX25 Kurs 6

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte
Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning
Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

MITRE ATT&CK används i ett säkerhetsteam för att beskriva och analysera hur angripare agerar. Ramverket är uppbyggt kring tactics och techniques. Tactics beskriver varför en angripare gör något. Techniques beskriver hur angriparen gör det. Det finns även sub-techniques som beskriver olika varianter av en teknik.

En viktig del med ATT&CK är att det ger säkerhetsteam ett gemensamt språk och en gemensam struktur. Istället för att bara skriva “konstig inloggning” som kan tolkas på olika sätt kan man till exempel skriva T1078 Valid Accounts. Då blir det tydligare vad man menar och andra kan enkelt söka upp tekniken och förstå vad som syftas på. Det gör det också lättare att jämföra analyser mellan olika team samt följa upp tidigare händelser.

ATT&CK kan även användas för att se hur bra organisationens försvar är. Ett säkerhetsteam kan gå igenom olika tekniker och bedöma om organisationen kan upptäcka eller förhindra dem. Det kan hjälpa teamet att se var det finns luckor i det befintliga skyddet.
En begränsning är att ATT&CK främst bygger på observerade angreppssätt. Nya metoder kan därför saknas och alla framtida sätt att genomföra attacker finns inte med i ramverket. Det prioriterar inte heller vilka tekniker som är viktigast för en viss organisation. Den prioriteringen behöver istället göras utifrån organisationens egna risker och behov.

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att “göra attacker”.

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

MITRE ATT&CK är ett analysramverk och ska därför användas för att förstå och analysera angrepp. Det är inte en checklista som ska användas för att genomföra en attack. Skillnaden är att ett analysramverk hjälper ett säkerhetsteam att strukturera information. En angreppsinstruktion skulle istället beskriva hur en attack faktiskt ska genomföras steg för steg.

Om ett säkerhetsteam undersöker en incident kan ATT&CK användas för att strukturera och beskriva det beteende som har observerats. Det kan hjälpa teamet att förstå angreppet och vilka delar som behöver undersökas vidare. Informationen kan sedan användas för att ställa frågor om upptäckt och försvar.

Att använda ATT&CK som en checklista för att genomföra attacker skulle därför bli väldigt fel. Alla tekniker behöver inte användas vid ett angrepp. Vilka tekniker som används beror på angriparen och situationen. En lista över tekniker säger därför inte automatiskt hur en riktig attack kommer att se ut.
ATT&CK ska alltså hjälpa säkerhetsteamet att förstå och beskriva angripares beteenden. Det ska sedan användas som underlag för defensiv analys. Det är något annat än att få instruktioner för hur man själv ska genomföra ett angrepp.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

1. Reconnaissance- Angriparen samlar information om organisationen som kan användas inför ett angrepp.
2. Resource Development- Angriparen skaffar eller förbereder sådant som behövs för senare delar av angreppet.
3. Initial Access- Angriparen försöker få sin första åtkomst till organisationens system eller nätverk.
4. Persistence- Angriparen försöker behålla sin åtkomst till systemet även om något förändras.
5. Discovery- Angriparen undersöker organisationens system och resurser för att förstå miljön.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

MITRE ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning genom att ge dem ett gemensamt språk och en gemensam struktur. Red team kan använda ATT&CK för att beskriva vilka tekniker som har använts under en säkerhetsövning. Blue team kan sedan beskriva vilka tekniker de kunde upptäcka och vilka delar av försvaret som fungerade eller hade brister.

Det gemensamma språket gör kommunikationen tydligare mellan teamen. Istället för att bara beskriva något som en “misstänkt inloggning” kan man koppla det till en specifik teknik. Då blir det lättare att förstå vad som hänt och följa upp det senare. Det skapar också bättre spårbarhet eftersom man kan se vilka tekniker som testades och hur organisationen hanterade dem.

ATT&CK kan även användas för prioritering. Om red team hittar flera brister kan blue team och ledningen använda informationen för att bedöma vilka områden som behöver åtgärdas först. Ledningen behöver inte kunna alla tekniska detaljer. ATT&CK kan istället ge ett tydligare underlag för att förstå vilka delar av säkerheten som har testats och vilka brister som har upptäckts.

På så sätt kan ATT&CK fungera som en gemensam grund för red team, blue team och ledning. Alla behöver inte ha samma tekniska kunskap. De kan ändå utgå från samma struktur när de diskuterar resultat och förbättringar.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

Tactic, technique och procedure beskriver olika nivåer av en angripares beteende.
En tactic beskriver varför angriparen gör något och vilket mål angriparen har. En technique beskriver hur angriparen kan uppnå målet. En procedure beskriver ett konkret exempel på hur en technique har använts.

Ett defensivt exempel kan vara att en angripare försöker komma åt användares inloggningsuppgifter. Tacticen är då Credential Access eftersom målet är att få tillgång till inloggningsuppgifter. En technique kan vara T1555 Credentials

from Password Stores. En procedure kan sedan beskriva ett specifikt observerat fall där angriparen har använt denna technique.
Kort sagt beskriver tactic varför. Technique beskriver hur. Procedure beskriver ett konkret exempel på hur tekniken har använts.

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

1. T1078 Valid Accounts
   Tactic: Initial Access, Persistence, Privilege Escalation, Defense Evasion
   Technique: Valid Accounts
   Procedure: En angripare använder giltiga inloggningsuppgifter för att få tillgång till ett konto eller en resurs. För ett säkerhetsteam kan det vara viktigt att undersöka om inloggningen stämmer överens med användarens normala beteende.

2: T1059 Command and Scripting Interpreter
   Tactic: Execution
   Technique: Command and Scripting Interpreter
   Procedure: En angripare använder kommandon eller ett skript för att utföra något på ett system. Ett säkerhetsteam kan därför undersöka användningen av kommandon och skript för att upptäcka misstänkt aktivitet.

3: T1562.001 Impair Defenses: Disable or Modify Tools
   Tactic: Defense Evasion
   Technique: Impair Defenses: Disable or Modify Tools
   Procedure: En angripare försöker påverka säkerhetsverktyg så att de inte fungerar som de ska eller inte kan upptäcka aktiviteten. Ett säkerhetsteam kan därför behöva följa upp förändringar i säkerhetsverktyg och deras konfiguration.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tacticen.

Jag har valt Tactic: Execution
T1059 Command and Scripting Interpreter
Den passar eftersom tekniken handlar om att köra kommandon eller använda skript för att genomföra något på ett system.

T1204 User Execution
Den passar eftersom angriparen försöker få användaren att själv utföra något som leder till att angreppet kan fortsätta.

T1106 Native API
Den passar eftersom tekniken innebär att angriparen använder funktioner som finns i operativsystemets egna API för att genomföra aktiviteter på systemet.
Dessa tre tekniker hör till tacticen Execution eftersom de beskriver olika sätt som en angripare kan få något att köras eller utföras på ett system. Skillnaden mellan teknikerna är hur själva körningen sker.

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

Det kan vara svårt att mappa en observation till rätt teknik eftersom samma beteende kan ha flera möjliga förklaringar. Det är därför inte alltid möjligt att direkt avgöra vilken teknik som använts.

Kontexten är viktig för att kunna göra en bättre bedömning. En aktivitet som är normal i en organisation kan vara misstänkt i en annan. Man behöver därför förstå vad som hände före och efter observationen och vad användaren eller systemet normalt brukar göra.

Även datakvaliteten påverkar analysen. Om loggar saknas eller innehåller för lite information kan det vara svårt att avgöra vad som faktiskt hänt. Det kan då leda till att man mappar observationen till fel teknik eller blir för säker på en bedömning som egentligen är osäker.

Därför är det viktigt att använda källor när man mappar observationer till ATT&CK. Man kan till exempel kontrollera ATT&CKs egen beskrivning av tekniken och jämföra den med den information som finns från incidenten. Om det fortfarande är osäkert bör man dokumentera osäkerheten och undersöka om det finns mer information som kan stödja bedömningen.

Ett konkret exempel är en ovanlig inloggning. Den skulle kunna tolkas som T1078 Valid Accounts om kontouppgifterna är stulna. Men det skulle också kunna vara en anställd som loggar in från en ny plats av legitima skäl. Därför flaggas den i analysen eftersom inloggningen skedde tillsammans med en avvikande tidpunkt. Men det dokumenterades ändå att den alternativa tolkningen inte kunde uteslutas helt.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

1: Initial Access: Angriparen får åtkomst till organisationens miljö.
2: Persistence: Angriparen försöker behålla sin åtkomst så den kan användas igen.
3: Privilege Escalation: Angriparen försöker få högre behörighet än den ursprungliga åtkomsten.
4: Discovery: Angripare undersöker system och resurser för att förstå miljön och hitta sådant som kan vara värdefullt.
5: Impact: Angriparen påverkar system eller verksamhet på ett sätt som får negativa konsekvenser för organisationen.

Uppgift 10

Beskriv varje steg i er kedja med “varför”, “hur” och “vad såg vi?”.

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

1. Initial Access
   Varför (Tactic): Angriparen behöver få åtkomst till organisationens miljö.
   Hur (Technique T1078 Valid Accounts): Genom att använda en giltig åtkomst eller annan metod för att komma in.
   Vad vi såg (Procedure): En inloggning eller annan aktivitet som tyder på att en obehörig person har fått åtkomst.

2. Persistence
   Varför (Tactic): Angriparen vill kunna behålla åtkomsten även om den ursprungliga åtkomsten försvinner.
   Hur (Technique: T1098 Account Manipulation): Genom att skapa eller utnyttja en möjlighet att komma tillbaka till miljön.
   Vad vi såg (Procedure): Förändringar eller aktivitet som inte stämmer överens med det normala beteendet.

3: Privilege Escalation
   Varför (Tactic): Angriparen vill få högre behörighet för att kunna komma åt fler resurser.
   Hur (Technique: T1548 Abuse Elevation Control Mechanism): Genom att utnyttja en möjlighet att öka sina behörigheter.
   Vad vi såg (Procedure): Aktivitet som visar ett konto eller en process som plötsligt fått högre behörighet.

4. Discovery
   Varför (Tactic): Angriparen behöver förstå organisationens miljö och vilka resurser som finns.
   Hur (Technique: T1046 Network Service Discovery): Genom att undersöka system och resurser i miljön.
   Vad vi såg (Procedure): Aktivitet som visar att någon har undersökt system eller resurser på ett ovanligt sätt.

5: Impact
   Varför (Tactic): Angriparen vill påverka organisationens system eller verksamhet.
   Hur (Technique: T1486 Data Encrypted for Impact): Genom att påverka tillgänglighet, integritet eller annan viktig funktion.
   Vad vi såg (Procedure): En förändring eller störning i ett system som kan kopplas till angriparens tidigare aktivitet.

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

Det mest osäkra steget i attackkedjan är Initial Access eftersom vi inte vet exakt hur angriparen fick den första åtkomsten. För att kunna göra en bättre bedömning skulle vi behöva mer information från exempelvis inloggningsloggar och annan information om den första misstänkta aktiviteten.

Även Persistence är osäkert eftersom vi inte vet hur angriparen kunde behålla sin åtkomst. Här skulle vi behöva mer information om förändringar i system och konton.

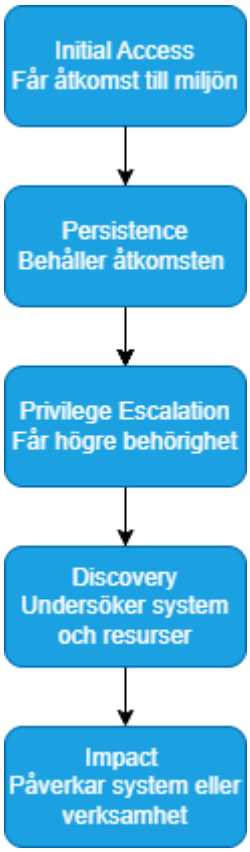
Det finns också osäkerheter i de senare stegen. Det behövs mer information för att kunna avgöra om aktiviteten faktiskt hör ihop och om den kan kopplas till samma angripare.

Det är därför viktigt att dokumentera vad man vet och vad man inte vet. På så vis blir det tydligare vilka delar av attackkedjan som behöver undersökas vidare.
Kedjan visar också att en svaghet tidigt i attacken påverkar riskbilden för hela förloppet. Om Initial Access hade kunnat upptäckas direkt hade de senare stegen aldrig behövt inträffa. Det visar varför det är viktigt att se attackkedjan som en helhet och inte bara bedöma varje steg för sig.

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller punktlista.



Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

1. Initial Access
   Hur kan vi upptäcka om någon obehörig har fått tillgång till organisationens system?

2. Persistence
   Hur kan vi upptäcka om en angripare försöker behålla sin åtkomst till systemet?

3. Privilege Escalation
   Hur kan vi upptäcka om ett konto plötsligt får högre behörigheter än det brukar ha?

4. Discovery
   Hur kan vi upptäcka om en angripare börjar undersöka organisationens system och resurser?

5. Impact
   Hur kan vi upptäcka om en angripare försöker påverka organisationens system eller verksamhet?

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

T1078 Valid Accounts
Om en användare loggar in på ett sätt som skiljer sig från det vanliga kan det tyda på att något är fel. Det kan till exempel vara från en ovanlig plats eller vid en ovanlig tid. Flera ovanliga inloggningar kan också vara ett tecken på att någon annan använder kontot.

T1059 Command and Scripting Interpreter
Om en användare kör kommandon eller skript på ett sätt som skiljer sig från det vanliga kan det betyda att något är fel. Det kan till exempel vara om en användare som vanligtvis inte använder kommandon plötsligt börjar göra det. Om aktiviteten dessutom sker tillsammans med en annan ovanlig aktivitet kan det vara ett tecken på att något inte stämmer.

Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

T1078 Valid Accounts
En teknisk åtgärd kan vara att använda multifaktorautentisering. Då räcker det inte bara med ett lösenord för att logga in. En processmässig åtgärd kan vara att regelbundet kontrollera vilka personer som har tillgång till olika konton och system. Då kan onödiga åtkomster tas bort. Om resurserna är begränsade bör multifaktorautentisering prioriteras först eftersom den stoppar flest angreppsvägar direkt, som till exempel brute force och läckta lösenord. Regelbunden kontogranskning är en långsiktig åtgärd som kan genomföras därefter.

T1059 Command and Scripting Interpreter
En teknisk åtgärd kan vara att begränsa vilka användare eller system som får använda vissa kommandon eller skript. Det kan också vara bra att ha regler för när och hur det får användas. Genom att logga användningen kan man lättare upptäcka om någon använder kommandon eller skript på ett ovanligt sätt.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

En attackkedja kan hjälpa ett säkerhetsteam att förstå hur olika delar av ett angrepp hänger ihop. Genom att gå igenom kedjan steg för steg kan teamet se vad som har hänt och var organisationens försvar har fungerat eller haft brister.

Attackkedjan kan också användas för att lära sig av tidigare händelser och säkerhetsövningar. Om teamet till exempel upptäcker att en viss del av kedjan var svår att upptäcka kan det visa att det behövs bättre loggning eller andra kontroller. På så sätt kan teamet använda det man har lärt sig för att förbättra sitt försvar.

Kedjan kan även hjälpa till med prioritering. Om det finns flera brister kan allt inte åtgärdas samtidigt. Teamet kan bedöma vilka brister som innebär störst risk och börja med dem. Det kan till exempel vara viktigt att först åtgärda en brist som kan ge angriparen fortsatt åtkomst till organisationens system.
Efter att åtgärder har gjorts behöver de också följas upp. Teamet kan kontrollera om förändringarna faktiskt har förbättrat möjligheten att upptäcka eller stoppa aktiviteten. Om en ny säkerhetsövning genomförs kan resultatet jämföras med tidigare resultat.

På så sätt blir attackkedjan inte bara en beskrivning av ett angrepp. Den kan användas som ett sätt att lära sig av tidigare händelser. Den kan också hjälpa säkerhetsteamet att prioritera förbättringar och följa upp om de faktiskt har gett bättre skydd.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

MITRE ATT&CK-T1598 Phishing for Information
Vi använder MITRE ATT&CK för att kontrollera vilken tactic och technique som passar till observationen. T1598 används för att beskriva Phishing for Information och hör till Reconnaissance. Phishing for Information, Technique T1598 - Enterprise | MITRE ATT&CK®

MITRE ATT&CK-T1566.001 Spearphishing Attachment
Denna källa används för att kontrollera vår mappning av phishing med en skadlig bilaga. Den visar att T1566.001 är en sub-technique till Phishing och hör till Initial Access. Phishing: Spearphishing Attachment, Sub-technique T1566.001 - Enterprise | MITRE ATT&CK®

MITRE ATT&CK-T1204.002 User Execution: Malicious File
Denna källa används för att kontrollera steget där användaren öppnar en skadlig fil. Den beskriver T1204.002 och visar att tekniken tillhör Execution. User Execution: Malicious File, Sub-technique T1204.002 - Enterprise | MITRE ATT&CK®

MITRE ATT&CK-T1046 Network Service Discovery

Denna källa används för att kontrollera vår mappning av nätverksskanning. Den beskriver T1046 och visar att tekniken hör till Discovery. [Network Service Discovery, Technique T1046 - Enterprise | MITRE ATT&CK®]

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

Vi säkerställer att vår TTP-mappning är rimlig genom att använda MITRE ATT&CK som källa och jämföra våra observationer med beskrivningen av den aktuella tekniken. Vi behöver också kunna motivera varför vi har valt en viss tactic och technique utifrån det beteende vi har observerat.

Om det finns flera möjliga tekniker behöver vi vara tydliga med att mappningen är osäker. Då kan vi dokumentera vad vi behöver veta mer om för att kunna göra en säkrare bedömning.

Innan mappningen är färdig bör någon annan i gruppen granska den. Då kan vi upptäcka om vi har missat något eller om någon annan tycker att en annan teknik passar bättre. På så sätt blir mappningen mer genomtänkt och spårbar. Samtidigt har källorna sina begränsningar. MITRE ATT&CK beskriver vilka tekniker som finns men säger inget om vilka som är mest relevanta för just vår organisation. Den bedömningen måste vi göra själva utifrån vår egen miljö och hotbild.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

En färdig hotanalys ska uppfylla följande:

- Attackkedjan är komplett och har en tydlig början och ett slut.
- Varje steg har en relevant tactic och technique.
- Det finns minst en försvarsfråga för varje steg i attackkedjan.
- Källorna till TTP-mappningen är dokumenterade.
- Osäkerheter och antaganden är dokumenterade.
- Analysen har granskats av någon annan i gruppen innan den godkänns.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

En hotanalys blir användbar för andra om den är tydlig och går att förstå även för någon som inte var med och gjorde analysen. Det ska gå att se vad som har analyserats, vilka tekniker som har valts och varför de har valts.

Det är också viktigt att analysen är spårbar. Källorna ska finnas dokumenterade så att någon annan kan kontrollera var informationen kommer ifrån. Det ska även framgå vad som är fakta och vad som är antaganden. Om det finns osäkerheter eller information som saknas bör det dokumenteras.

Analysen behöver också anpassas efter mottagaren. Ett säkerhetsteam kan behöva mer tekniska detaljer för att

kunna följa upp och förbättra försvaret. Ledningen behöver däremot främst kunna förstå riskerna och vad som behöver prioriteras.

Samtidigt behöver analysen inte innehålla all information som finns. Den ska vara tillräckligt detaljerad för att andra ska kunna förstå och följa arbetet, men inte innehålla onödig information.

På så sätt kan någon annan ta över analysen. De kan förstå hur slutsatserna har kommit fram och använda informationen för fortsatt säkerhetsarbete.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

- Utökat vår Definition of done.
  Vi lade till fler punkter och gjorde kriterierna tydligare.

- Delat backlog-itemet om inventering i två.
  Vi delade upp det i “Lista organisationens tillgångar” och “Sammanställ en lista på godkända mjukvaror.” Tidigare låg båda i samma backlog-item. De har olika prioriteringar och kan därför hanteras som två separata items.

- Skapat en checklista inför workshop 3.
  Checklistan ger oss bättre struktur och gör det enklare att kontrollera att allt är klart inför nästa workshop.

- Skapa en TTP-tabell.
  Detta blir en förberedelse inför det kommande projektet och ger oss möjlighet att använda det vi har arbetat med i workshop 2.

- Lagt till att vi ska planera nästa steg.
  Det blir lättare att planera hur det fortsatta arbetet ska läggas upp och vad som behöver göras härnäst.

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Vårt Sprint Goal fokuserade framförallt på att bygga upp vårt team och skapa ett tydligt arbetssätt och struktur. Attackkedjan blev en del av det arbetssättet och gav oss träning i hur vi kan arbeta med hotanalys. Sprintmålet var därför relevant för workshop 2. Den kommer att behöva justeras så det passar nästa projekt.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

Har vi nått vårt mål?
Om inte, varför? Om ja, vad gick bra?
Har vårt arbetssätt fungerat bra eller behöver vi ändra något?

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

Vad gick bra

- Mötesplaneringen fungerade bra.
- Alla var bra på att närvara.
- Det var smidigt att skapa Kanban-board.
- Det var smidigt och användarvänligt att göra checklistor.

Vad som blev svårt

- Vi hade önskat mer information om projektet för att enklare kunna jobba efter det.
- Det var svårt att hitta information som svar på vissa av våra frågor.
- Vi hade gärna sett en tydligare demonstration av det agila arbetssättet så det blev tydligare hur man gör i praktiken.

Vad vi vill ändra

- Vi kom inte på något speciellt här. Vi tycker att det har fungerat bra.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: https://attack.mitre.org/
- MITRE ATT&CK Enterprise Matrix: https://attack.mitre.org/matrices/enterprise/
- CISA - Best Practices for MITRE ATT&CK Mapping: https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping
- MITRE ATT&CK Data & Tools: https://attack.mitre.org/resources/attack-data-and-tools/

AI-användning: Jag använde Claude som jag promptade till anpassad studiehjälp för mina behov. Som t ex att granska mina svar och komma med feedback innan inlämning. All text är dock skriven av mig.

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&CK som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor och begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)
Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)
Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.